

CYBERSECURITY & ETHICAL HACKING

Authentication Cracking con Hydra

Corso	Cybersecurity & Ethical Hacking
Anno Accademico	2026
Tipo Esercitazione	Project Work di Fine Settimana
Servizi Testati	- SSH (porta 22) - FTP vsFTPD (porta 21) - HTTP Apache2 (porta 80)
Tool Utilizzato	Hydra (THC-Hydra)
Data	15 Maggio 2026

1. Introduzione

In questa esercitazione ho avuto modo di usare Hydra, uno dei tool di password cracking piu' noti nell'ambito del penetration testing, per effettuare attacchi a dizionario su diversi servizi di rete configurati direttamente sulla mia macchina virtuale Kali Linux. L'obiettivo principale era verificare che, partendo da un utente con credenziali note, Hydra fosse in grado di recuperare la password corretta scorrendo le wordlist disponibili nel sistema.

Per rendere i test il piu' realistici possibile ho prima creato un utente di sistema chiamato test_user con una password volutamente semplice e presente nelle wordlist piu' comuni, ovvero password123. I servizi presi in esame sono stati tre: SSH sulla porta 22, FTP tramite il demone vsFTPD sulla porta 21, e HTTP Basic Auth sulla porta 80 con Apache2. Per ognuno di questi ho prima avviato e configurato il servizio, poi lanciato Hydra con le opzioni appropriate, verificando infine il risultato ottenuto.

L'esercitazione mi ha permesso non solo di fare pratica con Hydra e le sue diverse modalita' di attacco, ma anche di approfondire la configurazione di servizi di rete molto comuni come SSH, FTP e Apache2, comprendendo meglio i meccanismi di autenticazione che li governano e le principali vulnerabilita' legate all'uso di password deboli.

2. Obiettivi

Obiettivo	Descrizione
Pratica con Hydra	Utilizzare Hydra con diverse wordlist e moduli per attaccare tre servizi di rete distinti.
Consolidamento sui servizi di rete	Configurare e avviare SSH, FTP e HTTP su Kali Linux, comprendendo il funzionamento di ciascuno.
Modifica dei file di configurazione	Modificare sshd_config per rimuovere i limiti di autenticazione e configurare Apache2 per il Basic Auth.
Confronto tra wordlist	Valutare le differenze tra fasttrack.txt (263 voci) e rockyou.txt (14+ milioni di voci) in termini di velocità di cracking.

3. Ambiente e Strumenti

Sistema Operativo	Kali Linux 2026.1 — kernel 6.19.14-1+kali1 (2026-05-05) x86_64
Indirizzo IP VM	192.168.1.164
Hypervisor	Oracle VirtualBox — scheda di rete Bridged
Tool principale	Hydra (THC-Hydra)
Servizi testati	SSH porta 22 FTP vsFTPD 3.0.5 porta 21 HTTP Apache2 2.4.66 porta 80
Wordlist	fasttrack.txt (263 voci) per SSH/FTP rockyou.txt (14.344.399 voci) per HTTP
Utente di test	test_user -- password: password123

4. Procedura

STEP 1

Creazione dell'utente di test

Come prima cosa ho creato un utente di sistema chiamato test_user direttamente su Kali Linux, che avrebbe fatto da bersaglio per tutti i test successivi. Il comando usato e' stato il seguente:

```
sudo adduser test_user
```

Durante la creazione ho impostato la password password123, una scelta volutamente banale proprio per permettere a Hydra di trovarla rapidamente nelle wordlist. Ho poi verificato che l'accesso funzionasse collegandomi via SSH alla stessa macchina (192.168.1.164) con le credenziali appena create. Al primo tentativo il sistema ha presentato l'impronta della chiave host ED25519 con fingerprint SHA256:aY/HNoJu3yndUzg6bfmpYz0Pqf1lhClpgikXO9LUn7U, che ho accettato aggiungendola alla lista degli host conosciuti. Il login e' andato a buon fine, confermando che l'utente era attivo e le credenziali corrette.

STEP 2

Cracking SSH (porta 22)

Per il primo servizio ho attivato SSH, gia' presente su Kali Linux, ma mi sono subito accorto che la configurazione di default avrebbe ostacolato Hydra: il parametro MaxAuthTries era impostato su un valore molto basso, causando errori di connessione dopo pochi tentativi. Ho aperto il file di configurazione:

```
sudo nano /etc/ssh/sshd_config
```

All'interno ho modificato i seguenti parametri per rendere il servizio piu' permissivo durante i test:

```
StrictModes no  
MaxAuthTries 1000000  
MaxSessions 1000000
```

Dopo aver riavviato SSH ho lanciato Hydra con la wordlist fasttrack.txt, che contiene circa 263 password molto comuni:

```
hydra -l test_user -P /usr/share/wordlists/fasttrack.txt \  
192.168.1.164 ssh -V -f
```

Hydra ha scandito la lista tentando ogni password e al tentativo numero 124 di 263 ha trovato la corrispondenza corretta: login: test_user, password: password123. L'attacco e' terminato alle 06:01:11 del 15 maggio 2026.

STEP 3

Cracking FTP (porta 21)

Per il secondo test ho attivato il servizio FTP. Ho prima tentato di collegarmi alla macchina Metasploitable 2.0 (192.168.1.170), ma il sistema ha restituito l'errore 'No route to host', segno che la VM non era raggiungibile in quel momento. Ho quindi deciso di installare vsFTPD direttamente su Kali Linux, scelta che era sufficiente per l'obiettivo didattico dell'esercizio:

```
sudo apt install vsftpd
sudo systemctl start vsftpd
```

Ho verificato il servizio collegandomi manualmente tramite il client ftp: il banner mostrava vsFTPD 3.0.5 e il login ha restituito la risposta 230 Login successful. Ho quindi lanciato Hydra con lo stesso approccio usato per SSH, cambiando solo il modulo finale:

```
hydra -l test_user -P /usr/share/wordlists/fasttrack.txt \
192.168.1.164 ftp -V -f
```

Hydra ha trovato la password al tentativo 124 di 262, concludendo l'attacco alle 06:20:34 con il risultato: login: test_user, password: password123.

STEP 4

Cracking HTTP Basic Auth (porta 80)

Per l'ultimo servizio ho configurato Apache2 con HTTP Basic Auth sulla porta 80. Ho installato e avviato il server:

```
sudo apt install apache2
sudo systemctl start apache2
```

Ho poi creato il file delle credenziali per Apache, aggiungendo test_user con la password password123:

```
sudo htpasswd -c /etc/apache2/.htpasswd test_user
```

Ho quindi modificato il file di configurazione del virtual host per proteggere la directory principale con Basic Auth, aggiungendo il blocco seguente all'interno del tag VirtualHost in 000-default.conf:

```
<Directory "/var/www/html">
AuthType Basic
    AuthName "Area Protetta"
AuthUserFile /etc/apache2/.htpasswd
Require valid-user
</Directory>
```

Dopo aver abilitato i moduli auth_basic e authn_file e riavviato Apache2, ho verificato dal browser che apparisse correttamente il popup di login. Dato che rockyou.txt era ancora compresso l'ho decompresso prima di usarlo:

```
sudo gunzip /usr/share/wordlists/rockyou.txt.gz

hydra -l test_user -P /usr/share/wordlists/rockyou.txt \
192.168.1.164 http-get / -V -f
```

Con la wordlist rockyou.txt Hydra ha impiegato piu' tempo rispetto ai test precedenti, ma ha comunque trovato la password al tentativo 1415 di 14.344.399, concludendo l'attacco alle 07:13:24. Il pannello di stato di Apache2 confermava 314 richieste totali ricevute durante l'intera sessione di attacco.

5. Screenshot

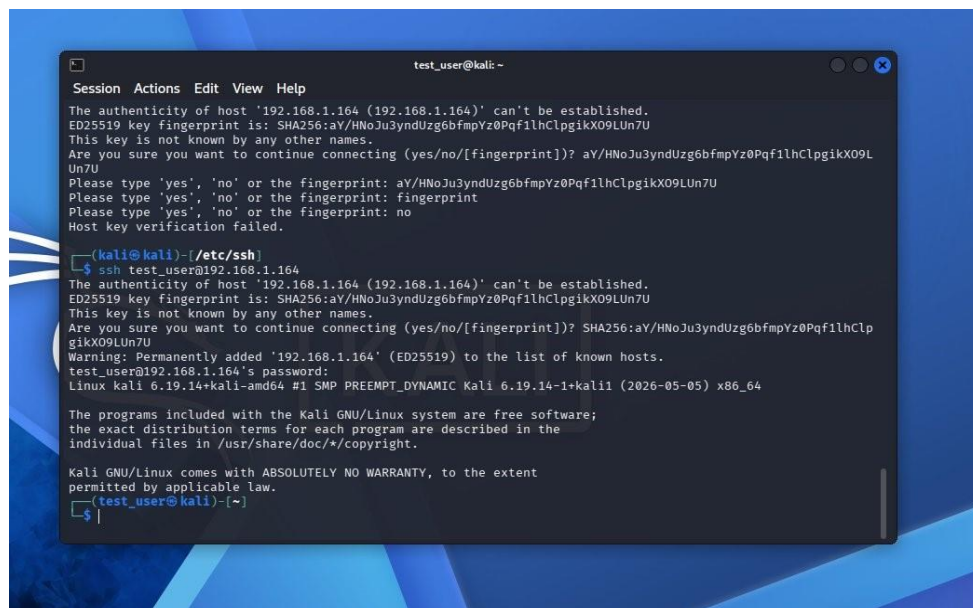


Fig. 1 — Creazione e verifica dell'utente test_user: login SSH riuscito su 192.168.1.164, kernel 6.19.14-1+kali1 (2026-05-05) x86_64. Il titolo del terminale in basso a destra mostra la sessione attiva come test_user.

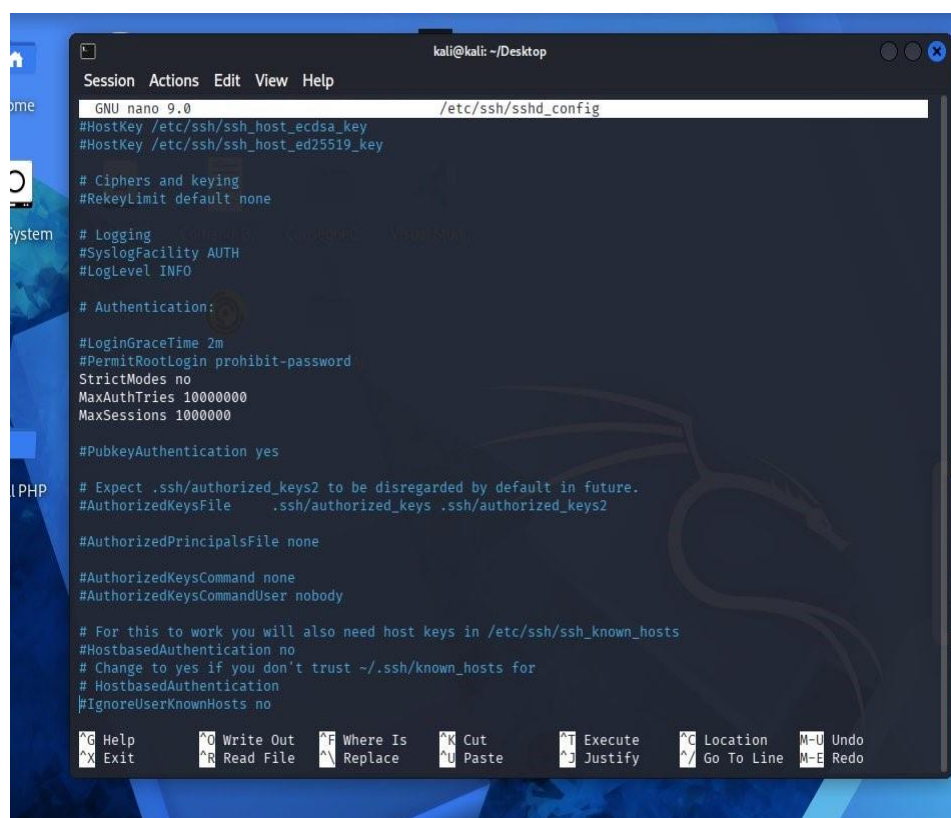


Fig. 2 — Modifica di /etc/ssh/sshd_config: StrictModes no, MaxAuthTries 10000000, MaxSessions 1000000, per consentire a Hydra di operare senza incontrare errori di connessione dovuti ai limiti di default.

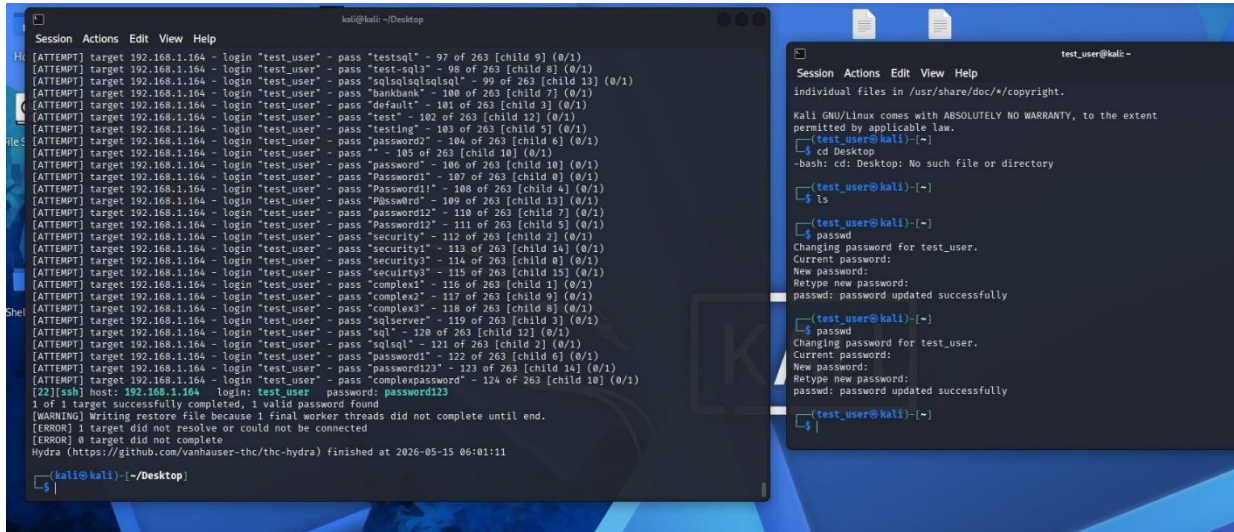


Fig. 3 — Hydra trova la password di test_user su SSH al tentativo 124/263 con fasttrack.txt (ore 06:01:11). A destra: la sessione test_user con il comando passwd usato per reimpostare le credenziali tra un test e l'altro.

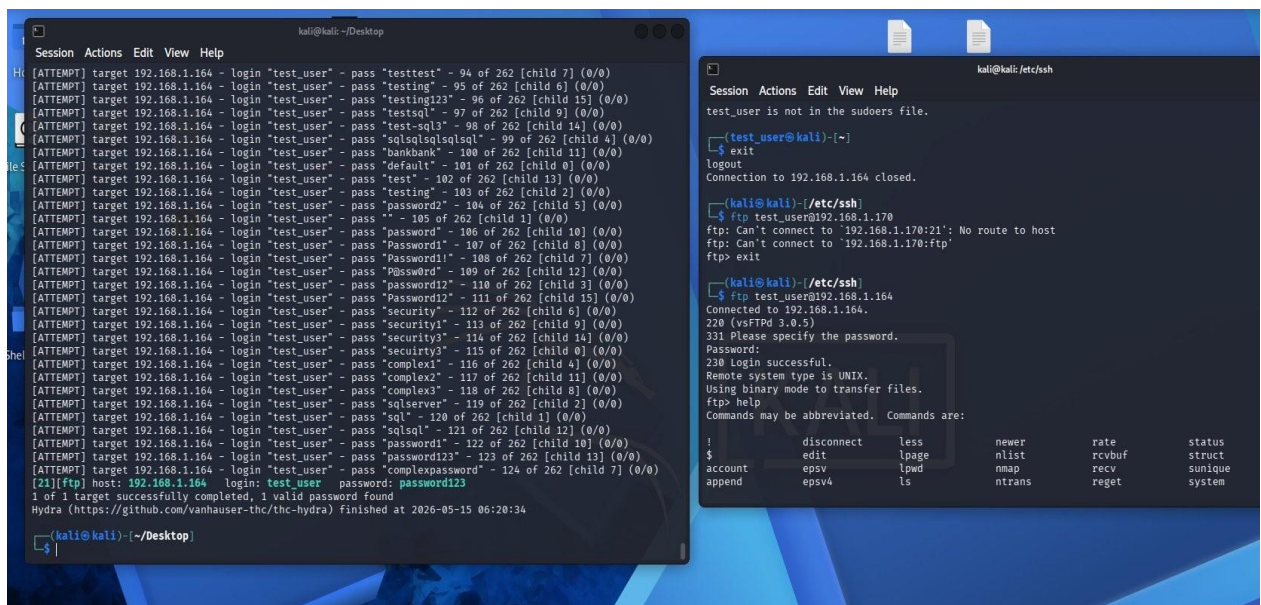


Fig. 4 — Hydra individua la password su FTP (vsFTPd 3.0.5) al tentativo 124/262. A destra: connessione FTP manuale riuscita su 192.168.1.164 con banner del servizio e risposta 230 Login successful.

```

kali@kali: ~/Desktop
Session Actions Edit View Help

(kali@kali)~[~/Desktop]
$ sudo systemctl status apache2
● apache2.service - The Apache HTTP Server
   Loaded: loaded (/usr/lib/systemd/system/apache2.service; disabled; preset: disabled)
   Active: active (running) since Fri 2026-05-15 06:50:17 EDT; 23s ago
     Invocation: c5782a59a0a84d03b630831763156b43
       Docs: https://httpd.apache.org/docs/2.4/
    Main PID: 121879 (apache2)
      Status: "Total requests: 0; Idle/Busy workers 100/0; Requests/sec: 0; Bytes served/sec: 0 B/sec"
        Tasks: 6 (limit: 9280)
       Memory: 20.6M (peak: 20.9M)
          CPU: 176ms
    CGroup: /system.slice/apache2.service
            └─121879 /usr/sbin/apache2 -k start -DFOREGROUND
              121895 /usr/sbin/apache2 -k start -DFOREGROUND
              121896 /usr/sbin/apache2 -k start -DFOREGROUND
              121897 /usr/sbin/apache2 -k start -DFOREGROUND
              121898 /usr/sbin/apache2 -k start -DFOREGROUND
              121899 /usr/sbin/apache2 -k start -DFOREGROUND

May 15 06:50:17 kali systemd[1]: Starting apache2.service - The Apache HTTP Server ...
May 15 06:50:17 kali apache2[121879]: AH00558: apache2: Could not reliably determine the server's fully
May 15 06:50:17 kali systemd[1]: Started apache2.service - The Apache HTTP Server.

(kali@kali)~[~/Desktop]
$ nmap -sV 192.168.1.164
Starting Nmap 7.99 ( https://nmap.org ) at 2026-05-15 06:53 -0400
Nmap scan report for kali.homenet.telecomitalia.it (192.168.1.164)
Host is up (0.000028s latency).
Not shown: 999 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
80/tcp    open  http      Apache httpd 2.4.66 ((Debian))

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.59 seconds

```

Fig. 5 — Apache2 attivo (running), PID principale 121879. Nmap conferma la porta 80/tcp aperta con Apache httpd 2.4.66 su Debian.

```

kali@kali: ~/Desktop
Session Actions Edit View Help

GNU nano 9.0 /etc/apache2/sites-enabled/000-default.conf
<VirtualHost *:80>
# The ServerName directive sets the request scheme, hostname and port that
# the server uses to identify itself. This is used when creating
# redirection URLs. In the context of virtual hosts, the ServerName
# specifies what hostname must appear in the request's Host: header to
# match this virtual host. For the default virtual host (this file) this
# value is not decisive as it is used as a last resort host regardless.
# However, you must set it for any further virtual host explicitly.
#ServerName www.example.com

ServerAdmin webmaster@localhost
DocumentRoot /var/www/html

<Directory "/var/www/html">
    AuthType Basic
    AuthName "Area Protetta"
    AuthUserFile /etc/apache2/.htpasswd
    Require valid-user
</Directory>

# Available loglevels: trace8, ..., trace1, debug, info, notice, warn,
# error, crit, alert, emerg.
# It is also possible to configure the loglevel for particular
# modules, e.g.
#LogLevel info ssl:warn

ErrorLog ${APACHE_LOG_DIR}/error.log
CustomLog ${APACHE_LOG_DIR}/access.log combined

# For most configuration files from conf-available/, which are
# enabled or disabled at a global level, it is possible to
# include a line for only one particular virtual host. For example the
# following line enables the CGI configuration for this host only

```

Fig. 6 — File 000-default.conf con il blocco Directory inserito per l'autenticazione HTTP Basic Auth: AuthType Basic, AuthUserFile .htpasswd, Require valid-user.

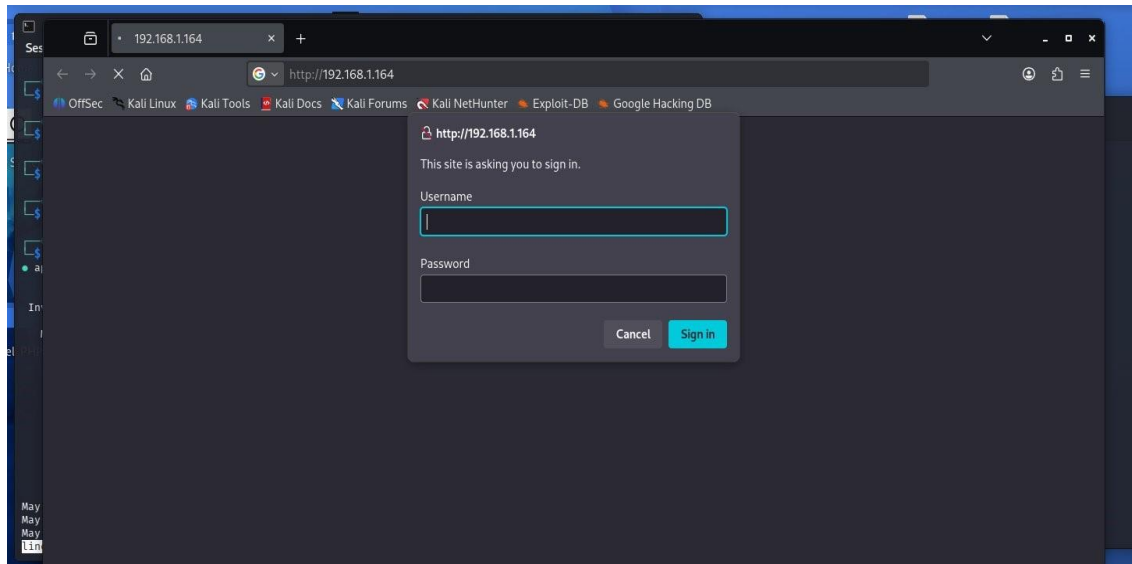


Fig. 7 — Popup di login HTTP Basic Auth mostrato dal browser su `http://192.168.1.164`, che conferma la corretta configurazione di Apache2 e del meccanismo di autenticazione attivo sulla porta 80.

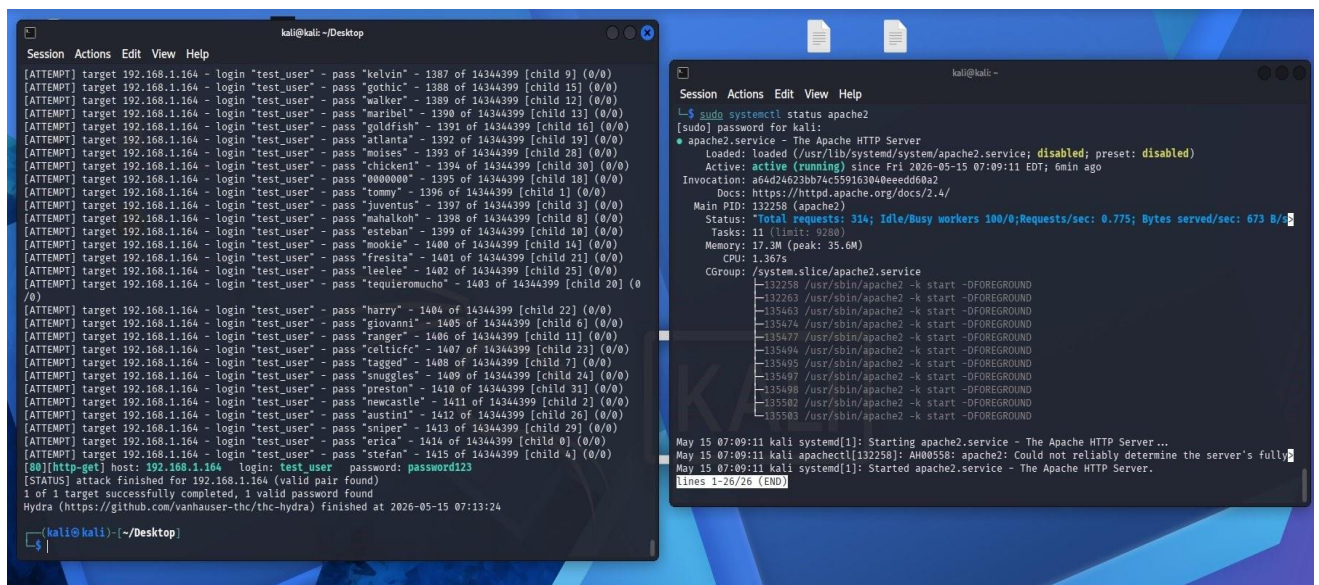


Fig. 8 — Hydra individua la password di `test_user` su HTTP Basic Auth al tentativo 1415 su 14.344.399 usando `rockyou.txt`. A destra: stato di Apache2 con 314 richieste totali registrate durante l'attacco.

6. Appendice & Comandi Principali

Creazione utente e configurazione SSH

```
# Creazione utente di test
sudo adduser test_user

# Avvio servizio SSH
sudo systemctl start ssh

# Parametri modificati in /etc/ssh/sshd_config
StrictModes no
MaxAuthTries 10000000
MaxSessions 1000000

# Cracking SSH con Hydra
hydra -l test_user -P /usr/share/wordlists/fasttrack.txt \
  192.168.1.164 ssh -V -f
```

Configurazione e cracking FTP

```
# Installazione e avvio vsFTPD
sudo apt install vsftpd
sudo systemctl start vsftpd

# Verifica connessione FTP manuale
ftp test_user@192.168.1.164

# Cracking FTP con Hydra
hydra -l test_user -P /usr/share/wordlists/fasttrack.txt \
  192.168.1.164 ftp -V -f
```

Configurazione Apache2 e cracking HTTP Basic Auth

```
# Installazione e avvio Apache2
sudo apt install apache2
sudo systemctl start apache2

# Creazione database credenziali
sudo htpasswd -c /etc/apache2/.htpasswd test_user

# Abilitazione moduli di autenticazione e riavvio
sudo a2enmod auth_basic authn_file sudo systemctl
restart apache2

# Decompressione rockyou.txt
sudo gunzip /usr/share/wordlists/rockyou.txt.gz

# Cracking HTTP Basic Auth con Hydra
hydra -l test_user -P /usr/share/wordlists/rockyou.txt \
  192.168.1.164 http-get / -V -f
```

7. Risultati

✓ SSH (porta 22) - Password trovata

Hydra ha individuato la password password123 per test_user al tentativo numero 124 su 263 della wordlist fasttrack.txt, concludendo l'attacco in pochi secondi. Il risultato dimostra quanto rapidamente Hydra possa craccare credenziali deboli anche su un protocollo cifrato come SSH.

✓ FTP (porta 21) - Password trovata

Anche contro il servizio FTP (vsFTPD 3.0.5) Hydra ha trovato la password corretta al tentativo 124 su 262, con la stessa wordlist fasttrack.txt. La connessione FTP manuale effettuata in precedenza aveva già confermato che il servizio era in ascolto e accettava le credenziali.

✓ HTTP Basic Auth (porta 80) - Password trovata

Con la wordlist rockyou.txt (14.344.399 voci) Hydra ha trovato la password al tentativo 1415. Il numero maggiore di richieste è confermato dal pannello di stato di Apache2, che registrava 314 richieste totali ricevute. Il modulo http-get ha funzionato correttamente con la configurazione HTTP Basic Auth impostata

8. Difficoltà Ricontrate

La prima difficoltà è emersa durante il test su SSH. Lanciando Hydra con la configurazione di default del servizio, ottenevo numerosi errori di connessione dopo pochi tentativi. Il motivo era il valore di default di MaxAuthTries nel file sshd_config, che interrompeva la connessione troppo presto. Ho dovuto aprire il file di configurazione e impostare valori molto più alti per MaxAuthTries e MaxSessions, oltre a disabilitare StrictModes. Solo dopo queste modifiche e il riavvio del servizio Hydra ha potuto operare correttamente e portare a termine l'attacco senza interruzioni.

La seconda difficoltà è emersa nel test FTP: avevo inizialmente tentato di collegarmi alla macchina Metasploitable 2.0 (192.168.1.170), ma il sistema ha restituito l'errore 'No route to host', segno che la VM non era attiva o raggiungibile. Ho quindi deciso di installare vsFTPD direttamente su Kali Linux, il che ha risolto il problema e mi ha anche permesso di capire meglio come configurare un server FTP da zero.

Nel test HTTP ho incontrato due piccoli problemi. Il primo riguardava rockyou.txt: su Kali Linux la wordlist è distribuita compressa in formato .gz, per cui prima di poterla usare ho dovuto decomprimerla con gunzip. Il secondo problema è stato con il browser: dopo il primo accesso riuscito, Firefox metteva in cache le credenziali e non mostrava più il popup di login. Eseguire un hard refresh con Ctrl+Shift+R ha risolto il problema e il popup di autenticazione è tornato visibile correttamente.

9. Conclusioni

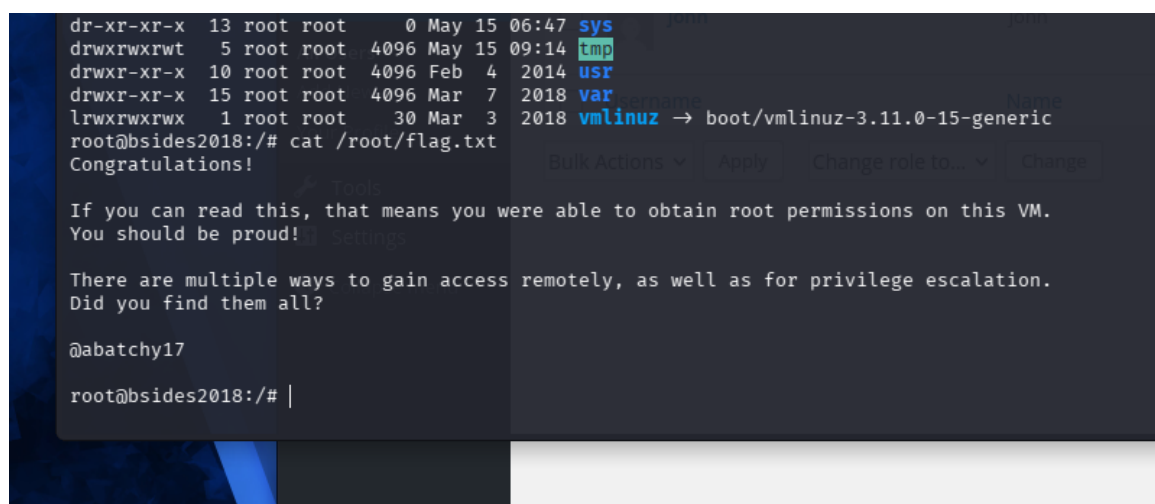
Questa esercitazione e' stata molto utile per capire in pratica come funzionano gli attacchi a dizionario condotti con Hydra. Ho avuto modo di testare lo strumento su tre protocolli diversi, SSH, FTP e HTTP Basic Auth, e in tutti e tre i casi la password e' stata trovata con successo. La scelta di una password banale come password123 ha reso evidente quanto sia rapido per un attaccante recuperare credenziali deboli, indipendentemente dal protocollo utilizzato.

Un aspetto che ho trovato interessante e' stato confrontare i tempi di attacco usando due wordlist di dimensioni molto diverse. Con fasttrack.txt, che contiene solo 263 voci molto comuni, l'attacco si e' concluso in pochi secondi su entrambi SSH e FTP, perche' password123 era tra le prime cento voci. Con rockyou.txt su HTTP il numero di tentativi totali era enormemente piu' alto in assoluto, ma la password e' comunque stata trovata entro i primi 1500 tentativi, a conferma che le password comuni vengono identificate rapidamente anche con wordlist di milioni di voci.

Dal punto di vista della configurazione dei servizi ho imparato concretamente come funziona il file sshd_config e quali parametri influenzano la resistenza del servizio agli attacchi brute-force, come configurare vsFTPD su una macchina Linux, e come impostare HTTP Basic Auth su Apache2 usando htpasswd e il blocco Directory nel file di configurazione del virtual host. Queste competenze mi saranno utili non solo per comprendere le tecniche di attacco, ma soprattutto per capire come configurare i servizi in modo sicuro in un contesto reale.

Report redatto nell'ambito del Corso di Cybersecurity & Ethical Hacking, Anno Accademico 2026.

10. BONUS:



```
dr-xr-xr-x 13 root root    0 May 15 06:47 sys
drwxrwxrwt  5 root root 4096 May 15 09:14 tmp
drwxr-xr-x 10 root root 4096 Feb  4 2014 usr
drwxr-xr-x 15 root root 4096 Mar  7 2018 var
lrwxrwxrwx  1 root root    30 Mar  3 2018 vmlinuz → boot/vmlinuz-3.11.0-15-generic
root@bsides2018:/# cat /root/flag.txt
Congratulations!

If you can read this, that means you were able to obtain root permissions on this VM.
You should be proud!

There are multiple ways to gain access remotely, as well as for privilege escalation.
Did you find them all?

@abatchy17

root@bsides2018:/# |
```